HKCT Higher Diploma in Cybersecurity (Testing and Compliance)

03CIT4067 Cybersecurity Project Bi-weekly Meeting

Minutes of the 2nd Bi-weekly Meeting

Date: 2026-11-03 (Tuesday)
Venue: MUC 507 (face-to-face)
Participants:

Students:
Hui Ka Tung. Troy
Huang Kin Ming, William
Shi Hau Yan, Jessie

Lecturer : Liam Xu

Apologies:

Item	Description	Lecturer Feedback	Action by
Agenda #1	Testing Result on Kaggle Opensource csv	Test 3 public datasets	ALL
1.1	Phishing Guard AI	Upload function - expand url database	Troy
1.2	PhishingGuard	Expand semantic database	Jessie
1.3	NLP	Fine Tune “if metrics”	William
Agenda #2	Planning Directions	**Increse Accuracy** false positive rate too high expand URL database expand Phase semantic	ALL

		database Frequency tune metric **Efficiency** shorten testing duration **Redundancy** Cross check lower redundancy 3 tools integrated→ malicious → increase accurate rate **User friendly** web page graphs **Interpretability** result page export function user understand more	
Agenda #3	Date of next meeing	17/11/2026	ALL

Phishing Guard AI

Testing Result on 100 urls captured from the Phishing_Email.csv
result :
https://docs.google.com/spreadsheets/d/1qvqgK8ZI4xtHRWkqz9IuLs-SpkGy-NONRl4NIKJBHc8/edit?usp=sharing

Classification	Typical probability	Count (observed)	Notes
Dangerous (red)	95–100% (mostly 99–100%)	Vast majority	Correct detection of phishing URLs
Suspicion (yellow)	42.4%	At least 1	Page 54: `http://www.fasthizonline.com/bizopp/`
Safe (green)	18.4%	At least 1	Page 60: `http://www.affordable-domains.com/`

Page 54 URL

URL: http://www.fastbizonline.com/bizopp/
Found in email index 2927
Email Type: Phishing Email
Context: Classic multi-level marketing / “downline” spam promising free eBooks, guaranteed income, “FIRE YOUR BOSS”, etc.

Page 60 URL
URL: http://www.affordable-domains.com/ (and slight variants)
Found in three different emails:
Index 1904
Index 3095
Index 5289

All three are labeled: Phishing Email
Context: Domain registration spam promoting cheap .biz / .info domains for $14.95.

核心模型指標（在 **PhiUSIIL** 資料集驗證集上）

指標	數值	意義
PR-AUC	99.87%	精準率-召回率曲線下面積（幾乎完美區分釣魚與正常網址）
F1-Macro	99.40%	兩個類別的平衡 F1 分數
False Positive Rate	0.24%	約 26,970 個正常網址中，只有 66 個誤報
Brier Score	0.0052	機率校準極佳（0 為完美，0.25 為隨機）

分數如何計算

1. 特徵提取（僅使用 7 個 URL 特徵，不抓取網頁內容）：
    - TLDLegitimateProb（頂級域名合法性的貝葉斯／Wilson 先驗機率）
    - CharContinuationRate（字元重複率）
    - SpacialCharRatioInURL（特殊字元密度）
    - URLCharProb（字元分布機率）
    - LetterRatioInURL（字母比例）

    - NoOfOtherSpecialCharsInURL（其他特殊字元數量）
    - DomainLength（網域名稱長度）

2. 模型推論
    - 使用 **XGBoost**（梯度提升決策樹）
    - 輸出經過 **Isotonic Regression**（5 折交叉驗證）校準，讓機率更可靠。
3. 最終機率
    - 模型輸出 **p_malicious**（該 URL 為釣魚的機率），數值介於 0 到 1 之間。
4. 政策區間（決策規則）

p_malicious 範圍	決策	介面顯示意義
p < 0.011	ALLOW	安全（約 52% 案例）
0.011 ≤ p ≤ 0.998	REVIEW	灰區／可疑（轉交 LLM Judge）
p > 0.998	BLOCK	危險（約 36% 案例）

- 自動化率約 88%（直接 ALLOW 或 BLOCK）
- 約 12% 落入灰區，需由 LLM Judge 進一步判斷

介面顯示的百分比

你看到的百分比（例如「100.0% Dangerous」、「18.4% Safe」、「42.4% Suspicion」）直接來自校準後的 **p_malicious**：

- p_malicious 越高 → Dangerous 百分比越高
- p_malicious 越低 → Safe 百分比越高
- 中間範圍 → 顯示為 Suspicion / Review

PhishGuard

评分标准：`phishguard/engines/scoring.py`、**各分析器文件**、`config.py`

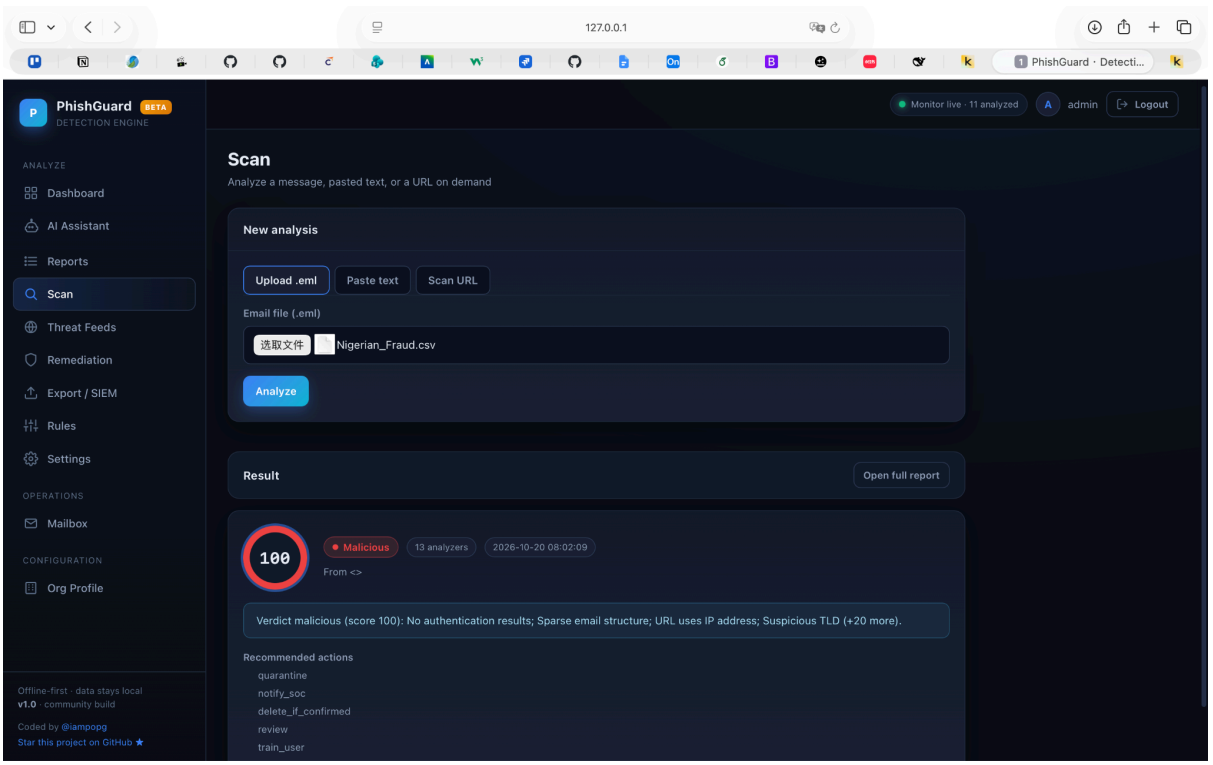
判定阈值：

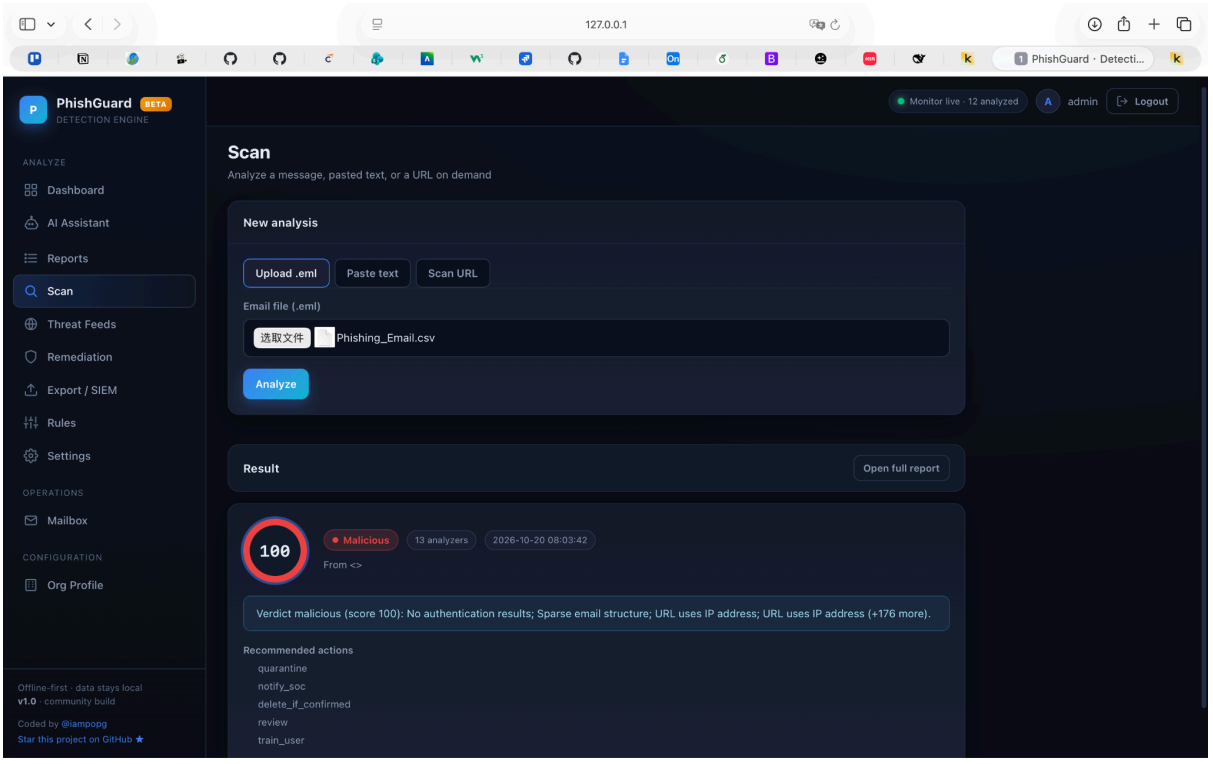
档位	条件
Safe	score < 30
Suspicious	30 ≤ score < 60
Phishing	60 ≤ score < 85
Malicious	score ≥ 85（上限 100）

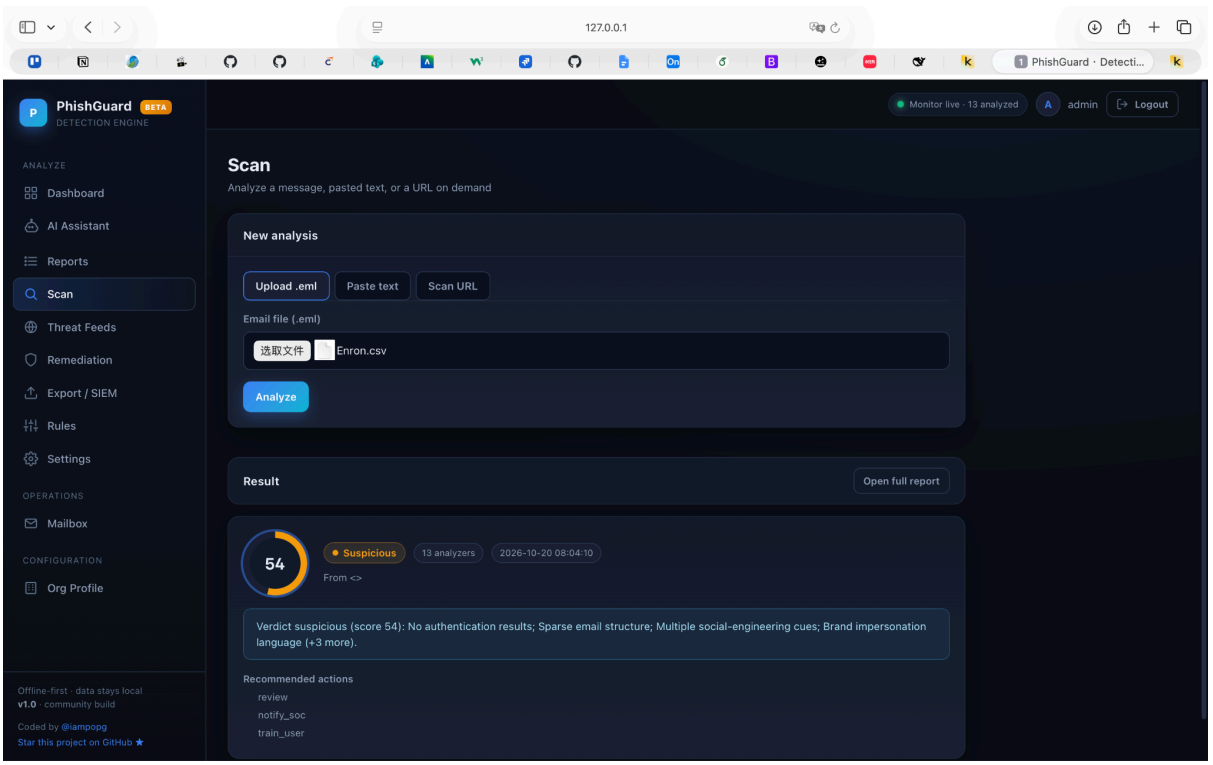
各分析器权重明细：

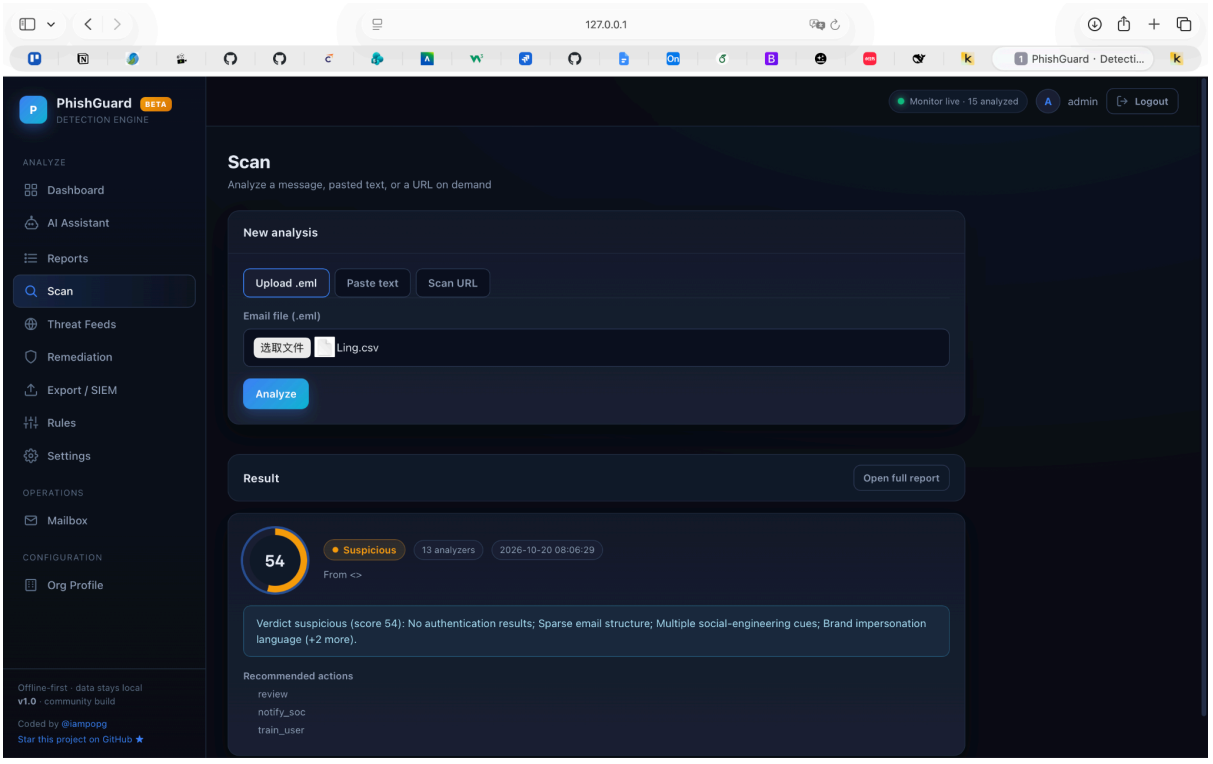
分析器	最大分	主要检测内容
url_scanner	60	URL 静态特征：IP 直连、可疑 TLD、短链等
header_auth	60	SPF / DKIM / DMARC 认证结果缺失或失败
attachment_analyzer	55	附件类型、可执行文件、宏
url_deep_scanner	50	深度访问 URL 验证（默认开启，超时 15 秒）
domain_reputation	50	域名信誉（需启用 DNS / 情报源）

header_analysis	45	邮件头结构：Reply-To 伪造等
sandbox	45	附件沙箱执行（默认关闭）
org_context	40	品牌 / 组织上下文冒充（需配置品牌表）
content_analyzer	40	内容话术：索要密码、验证码、紧急转账等
trust	40	发件人信任库评分
calendar	40	日历邀请钓鱼
qr_scanner	40	二维码内嵌 URL（需 pyzbar/PIL）
behavioral	40	行为分析（默认关闭）


127.0.0.1
PhishGuard · Detecti...
PhishGuard BETA
DETECTION ENGINE
Monitor live · 11 analyzed
admin
Logout
ANALYZE
Dashboard
AI Assistant
Reports
Scan
Threat Feeds
Remediation
Export / SIEM
Rules
Settings
OPERATIONS
Mailbox
CONFIGURATION
Org Profile
Offline-first · data stays local
v1.0 · community build
Coded by @iampopg
Star this project on GitHub ★
Scan
Analyze a message, pasted text, or a URL on demand
New analysis
Upload .eml
Paste text
Scan URL
Email file (.eml)
选取文件
Nigerian_Fraud.csv
Analyze
Result
Open full report
100
Malicious
13 analyzers
2026-10-20 08:02:09
From <>
Verdict malicious (score 100): No authentication results; Sparse email structure; URL uses IP address; Suspicious TLD (+20 more).
Recommended actions
quarantine
notify_soc
delete_if_confirmed
review
train_user


127.0.0.1
PhishGuard · Detecti...
PhishGuard BETA
DETECTION ENGINE
Monitor live · 12 analyzed
admin
Logout
ANALYZE
Dashboard
AI Assistant
Reports
Scan
Threat Feeds
Remediation
Export / SIEM
Rules
Settings
OPERATIONS
Mailbox
CONFIGURATION
Org Profile
Offline-first · data stays local
v1.0 · community build
Coded by @iampopg
Star this project on GitHub ★
Scan
Analyze a message, pasted text, or a URL on demand
New analysis
Upload .eml
Paste text
Scan URL
Email file (.eml)
选取文件
Phishing_Email.csv
Analyze
Result
Open full report
100
Malicious
13 analyzers
2026-10-20 08:03:42
From <>
Verdict malicious (score 100): No authentication results; Sparse email structure; URL uses IP address; URL uses IP address (+176 more).
Recommended actions
quarantine
notify_soc
delete_if_confirmed
review
train_user


127.0.0.1
PhishGuard · Detecti...
PhishGuard
BETA
DETECTION ENGINE
Monitor live · 13 analyzed
admin
Logout
ANALYZE
Dashboard
AI Assistant
Reports
Scan
Threat Feeds
Remediation
Export / SIEM
Rules
Settings
OPERATIONS
Mailbox
CONFIGURATION
Org Profile
Offline-first · data stays local
v1.0 · community build
Coded by @iampopg
Star this project on GitHub ★
Scan
Analyze a message, pasted text, or a URL on demand
New analysis
Upload .eml
Paste text
Scan URL
Email file (.eml)
选取文件
Enron.csv
Analyze
Result
Open full report
54
Suspicious
13 analyzers
2026-10-20 08:04:10
From <>
Verdict suspicious (score 54): No authentication results; Sparse email structure; Multiple social-engineering cues; Brand impersonation language (+3 more).
Recommended actions
review
notify_soc
train_user


127.0.0.1
PhishGuard · Detecti...
PhishGuard
BETA
DETECTION ENGINE
Monitor live · 15 analyzed
admin
Logout
ANALYZE
Dashboard
AI Assistant
Reports
Scan
Threat Feeds
Remediation
Export / SIEM
Rules
Settings
OPERATIONS
Mailbox
CONFIGURATION
Org Profile
Offline-first · data stays local
v1.0 · community build
Coded by @iampopg
Star this project on GitHub ★
Scan
Analyze a message, pasted text, or a URL on demand
New analysis
Upload .eml
Paste text
Scan URL
Email file (.eml)
选取文件
Ling.csv
Analyze
Result
Open full report
54
Suspicious
13 analyzers
2026-10-20 08:06:29
From <>
Verdict suspicious (score 54): No authentication results; Sparse email structure; Multiple social-engineering cues; Brand impersonation language (+2 more).
Recommended actions
review
notify_soc
train_user

上传文件	界面结果	真实含义
Phishing_Email.csv	**100 Malicious**（URL uses IP address +176 条）	整个 18,650 封邮件的文本被拼成一封 "巨型邮件"，大量 URL/IP 地址聚合触顶 100 分
Enron.csv	**54 Suspicious**	同上，整个 29,767 封拼一封，命中若干社交工程 / 品牌仿冒话术

上传文件	界面结果	触发点（截图可见）	真实含义
Ling.csv	**54 Suspicious**	No auth / Sparse structure / Social-engineering cues / Brand impersonation	整文件拼成一封大邮件，命中少量社交工程话术
Nigerian_Fraud.csv	**100 Malicious**	URL uses IP address; **Suspicious TLD** (+20 more)	数千封 419 诈骗信的 URL 聚合后触顶

数据集的真实构成：

数据集	真实记录数	正类	正类占比	整文件得分
Phishing_Email.csv	18,650	Phishing	39.3%	100 Malicious
Enron.csv	29,767	label=1	47.0%	54 Suspicious
Ling.csv	**2,859**（行数 5,476）	**label=1**（垃圾）	**16.0%**	**54 Suspicious**
Nigerian_Fraud.csv	**3,332**（行数 156,001）	**label=1**（诈骗，**100%** 单类）	**100%**	**100 Malicious**

逐条抽样评测：

指标	**Phishing_Email.csv**	**Enron.csv**
抽样数（正 / 负）	25 / 25	25 / 25
TP / FP / FN / TN	0 / 0 / 25 / 25	0 / 0 / 25 / 25
准确率	50.0%	50.0%
召回率（钓鱼检出率）	**0.0%**	**0.0%**
判定分布（真钓鱼类）	safe 25，suspicious 0	safe 24，suspicious 1

指标	**Ling.csv**	**Nigerian_Fraud.csv**
抽样正 / 负	25 垃圾 / 25 正常	25 诈骗（无负类）
TP / FP / FN / TN	0 / 0 / 25 / 25	检出 0 / 25
召回率 / 检出率	**0.0%**	**0.0%**
判定分布（正类）	safe 24，suspicious 1	safe 24，suspicious 1（平均分 15，最高 38）

为什么召回率是 0%

引擎的钓鱼信号在这批数据上全部落空，四组原因环环相扣：

1. 没有邮件头：数据集只有正文文本，`header_auth`、`header_analysis` 只能给 "无认证结果"（+5）这类基础分，抓不到 Reply-To 伪造等关键特征；
2. 内容风格不对：这些 "钓鱼" 样本大多是垃圾邮件式话术（广告、中奖、成人内容），不含引擎重点检测的 "索要密码 / 验证码 / 紧急 24 小时" 类凭证窃取短语（前面关键词统计显示 password/verify 在两类的命中率几乎相同，1.0%~1.6%）；
3. **URL** 维度熄火：默认不开 DNS 检查、不接威胁情报源，深度扫描对不可达链接只加 1 分（info 级），仿冒域名不会被识别；
4. 多项分析器关闭：behavioral、sandbox、QR 全关。

Nigerian 的 "错配" 最说明问题

它是最典型的 "看着该抓、却抓不到"：

1. 关键词统计显示：这 3,332 封信里 account 69.3%、bank 64.2%、transfer 60.6%、urgent 46.4% 出现 —— 话术特征极其明显；
2. 但引擎内容分析器盯的是 **"凭证窃取"** 短语（密码、验证码、登录、账单），对 "银行转账 / 王室遗产 / 海关包裹" 这类 419 话术没有命中规则；
3. 单封 **URL** 多为死链或普通域名，深度扫描也仅 +1 分；
4. 整文件上传时，3,332 封信的 URL 凑在一起才触发了 `URL uses IP address` + `Suspicious TLD` 聚合，把分数顶到 100——所以 **100** 分恰恰证明了它测的是 **"整包文本"**，不是单封。

NLP

用 phishing_email.csv（8.2万封邮件）测试钓鱼模型

> 这是一个**独立可运行**的 notebook：
>
> 1. 先用 spam.csv 训练模型（和原项目一样）
> 2. 再用 phishing_email.csv 的 82,486 封邮件做大规模测试
>
> 运行前请确保 `spam.csv` 和 `phishing_email.csv` 都在同一目录

[1]:
```
import numpy as np
import pandas as pd
import random
from sklearn.preprocessing import LabelEncoder
from sklearn.model_selection import train_test_split
from sklearn.feature_extraction.text import CountVectorizer
from sklearn.linear_model import LogisticRegression
from sklearn.metrics import accuracy_score, confusion_matrix
```

第一步：用 spam.csv 训练模型

[2]:
```
# 读取并清洗训练数据
df = pd.read_csv("spam.csv", encoding='ISO-8859-1')
df = df.drop(columns=['Unnamed: 2', 'Unnamed: 3', 'Unnamed: 4'])
df = df.rename(columns={'v1': 'TARGET', 'v2': 'MESSAGE'})
df = df.drop_duplicates(keep='first')

encoder = LabelEncoder()
df['TARGET'] = encoder.fit_transform(df['TARGET'])  # ham=0, spam=1

x = df['MESSAGE']
y = df['TARGET']
x_train, x_test, y_train, y_test = train_test_split(x, y, test_size=0.2, random_state=3)

cv = CountVectorizer()
x_train_cv = cv.fit_transform(x_train)
x_test_cv = cv.transform(x_test)

lr = LogisticRegression()
lr.fit(x_train_cv, y_train)

print(f"训练集准确率: {accuracy_score(y_train, lr.predict(x_train_cv))*100:.2f}%")
print(f"测试集准确率: {accuracy_score(y_test, lr.predict(x_test_cv))*100:.2f}%")
```

第一步：用 spam.csv 训练模型

[2]:
```
# 读取并清洗训练数据
df = pd.read_csv("spam.csv", encoding='ISO-8859-1')
df = df.drop(columns=['Unnamed: 2', 'Unnamed: 3', 'Unnamed: 4'])
df = df.rename(columns={'v1': 'TARGET', 'v2': 'MESSAGE'})
df = df.drop_duplicates(keep='first')

encoder = LabelEncoder()
df['TARGET'] = encoder.fit_transform(df['TARGET'])  # ham=0, spam=1

x = df['MESSAGE']
y = df['TARGET']
x_train, x_test, y_train, y_test = train_test_split(x, y, test_size=0.2, random_state=3)

cv = CountVectorizer()
x_train_cv = cv.fit_transform(x_train)
x_test_cv = cv.transform(x_test)

lr = LogisticRegression()
lr.fit(x_train_cv, y_train)

print(f"训练集准确率: {accuracy_score(y_train, lr.predict(x_train_cv))*100:.2f}%")
print(f"测试集准确率: {accuracy_score(y_test, lr.predict(x_test_cv))*100:.2f}%")
```

```
训练集准确率: 99.76%
测试集准确率: 97.58%
```

第二步：读取 phishing_email.csv 测试集

这个数据集两列：`text_combined`（邮件正文）、`label`（0=正常, 1=钓鱼）

[3]:
```
test_df = pd.read_csv("phishing_email.csv")
print(f"测试集总数: {len(test_df)} 封邮件")
print(test_df['label'].value_counts())
test_df.head()
```

```
测试集总数: 82486 封邮件
label
1    42891
0    39595
Name: count, dtype: int64
```

[3]:

	text_combined	label
0	hpl nom may 25 2001 see attached file hplno 52...	0
1	nom actual vols 24 th forwarded sabrae zajac h...	0
2	enron actuals march 30 april 1 201 estimated a...	0
3	hpl nom may 30 2001 see attached file hplno 53...	0
4	hpl nom june 1 2001 see attached file hplno 60...	0

第三步：批量预测（8万封可能需要 10~30 秒）

[4]:
```
X_new = test_df['text_combined'].astype(str)
y_new = test_df['label'].astype(int)

X_new_cv = cv.transform(X_new)
y_pred = lr.predict(X_new_cv)

acc = accuracy_score(y_new, y_pred)*100
tn, fp, fn, tp = confusion_matrix(y_new, y_pred).ravel()

print("=" * 60)
print(f"整体准确率: {acc:.2f}%")
print("=" * 60)
print(f"钓鱼邮件总数: {tp+fn} 封")
print(f"  正确检出:   {tp} 封  (召回率 {tp/(tp+fn)*100:.2f}%)")
print(f"  漏掉了:     {fn} 封  (漏判率 {fn/(tp+fn)*100:.2f}%)")
print(f"正常邮件总数: {tn+fp} 封")
print(f"  正确放行:   {tn} 封")
print(f"  误报为钓鱼: {fp} 封  (误报率 {fp/(tn+fp)*100:.2f}%)")
```

```
============================================================
整体准确率: 51.25%
============================================================
钓鱼邮件总数: 42891 封
  正确检出:   14231 封  (召回率 33.18%)
  漏掉了:     28660 封  (漏判率 66.82%)
正常邮件总数: 39595 封
  正确放行:   28041 封
  误报为钓鱼: 11554 封  (误报率 29.18%)
```

第四步：抽样看看判错的邮件长什么样

[5]:
```
# 随机抽 5 条漏掉的钓鱼邮件（实际是钓鱼，模型判成正常）
missed = [(i, t) for i, (t, p) in enumerate(zip(y_new, y_pred)) if t == 1 and p == 0]
random.seed(7)
print(f"—— 漏掉的钓鱼邮件共 {len(missed)} 封，随机抽 5 封展示 ——")
for i, _ in random.sample(missed, min(5, len(missed))):
    text = str(test_df.iloc[i]['text_combined'])
    print(f"\n[#{i}] {text[:180]}...")

# 随机抽 5 条误报的正常邮件（实际正常，模型判成钓鱼）
falses = [(i, t) for i, (t, p) in enumerate(zip(y_new, y_pred)) if t == 0 and p == 1]
print(f"\n\n—— 误报的正常邮件共 {len(falses)} 封，随机抽 5 封展示 ——")
for i, _ in random.sample(falses, min(5, len(falses))):
    text = str(test_df.iloc[i]['text_combined'])
    print(f"\n[#{i}] {text[:180]}...")
```

```
—— 漏掉的钓鱼邮件共 28660 封，随机抽 5 封展示 ——

[#37110] chick schroede gandinrobertoendesait trying find good chemists wont find better assortment site everything h
elp get rid bad conditioneven need fast delivery door always count us ge...

[#20812] travel world make money porn await lesion meet girl next door wants porn star see hot girls watch get fcuked
make money dreams come true make money porn would prefer receive messag...

[#42102] darrin connelly brightenfm6chinpuppyhavencom genericsproductsfriendlysupport httpaojnpqbaylivefilestorecomy1
pyiyvqargvgl3k7psodixi5rmo9_r4gzqpvlsk56tjjjhhkza1zcrgff514wwrfqmxgadykl...

[#59738] olen cochran dwstarmstarch p vnw harm js acy vis yai local target p xp h weg arm gk acy ge cxk ner ye ic dr
pxh ug ha owo fills httpsawgathercom thu 07 aug 2008 164348 0100 olen co...

[#10386] money 21362 dear homeowner pre approved 400 000 loan low fixed rate offer extended unconditionally credit wa
y factor take advantage limited time opportunity ask visit website compl...


—— 误报的正常邮件共 11554 封，随机抽 5 封展示 ——

[#5400] enron tiger kick donna jeff shankman join kickoff would like invite students faculty members dinner following
presentation recommendations regarding restaurant vince fap 11 08 2000...

[#52370] daryl c w oshea wlbpaliggfaddostechca rceejkejidanniorg wrote mk call older fashioned consider linewrapping
bit fancy mk config editing preferences see must billion column wide ter...

[#6463] previous summer intern dear giuseppe unfortunately longer associate analyst recruiting department unable assi
st directly please contact tracy warner responsible recruiting able ass...

[#31218] lexical semantics systems second workshop lexical semantics systems wlss98 april 6 7 final program monday ap
ril 6th 9 00 9 10 opening 9 10 9 50 j pustejovsky brandeis university ti...

[#60428] vvrpgsporcupineorg fmsfzcleechboxnet 2 tested 4000 smtpd processes limit saw much 2000 smtpd processes messa
ges tend pile incoming without moved active processes drop back trigger ...
```

二、实验对象

- **原模型**：用 `spam.csv`（5,169 条英文短信）训练，词袋统计 + 逻辑回归
- **修正了原代码两个 bug**：
  1. 测试集错误地重新 `fit_transform` 词表 → 改为 `transform`
  2. 错误地用测试集重新 `fit` 模型 → 改为 `predict`
- 修正后**同分布测试准确率为 97.58%**（原作者报告的 99.8% 是假的，属于数据泄露）

三、三个独立数据集的测试结果

表格

测试数据集	规模	准确率 / 检出率	说明
同分布测试集（spam.csv 拆分）	1,034 条	**97.58%**	在 "自家 现优秀
Nigerian 419 诈骗邮件	3,332 封	检出率 **85.41%**，误报 0%	因为含 free/mo t 等短信
Kaggle 多源真实邮件集	**82,486 封**（6 据集合并）	**整体 51.25%**，钓鱼召回率 **33.18%**，误报率	**几乎失效**

四、核心结论

1. **模型评分原理极其简单**：把邮件拆成单词 → 数词频 → 查一张 "单词权重表" 加权求和 → 正分判钓鱼、负分判正常。没有语义理解、不看链接 / 发件人 / 格式。
2. **权重表只学到了短信时代的词**（free、win、txt、prize、claim），遇到真实邮件里的贷款诈骗、SEO 堆砌、随机域名等新钓鱼手法，全部按 "陌生词 = 忽略" 处理。
3. **典型的 Domain Shift 问题**：训练数据（单一来源英文短信）和真实世界（6 来源混合邮件、长文本、多种钓鱼风格）分布完全不同，导致准确率从 97% 暴跌到 51%，漏掉了 **2/3 的真钓鱼邮件**，还错杀了 **1/3 的正常邮件**。
4. **结论**：这个工具作为教学 demo 是合格的，但**不能直接用于真实生产环境**—— 它在熟悉场景下好用，跨场景就接近瞎蒙。

五、改进方向（Weakness 对应）

- 用多来源真实邮件重新训练，而不是只靠短信库
- 加入 TF-IDF、n-gram、URL / 域名特征、发件人信息
- 换用能理解语义的模型（如 spaCy、Transformer）
- 处理类别不平衡，降低漏判率

Confirmed and signed by



03-11-2026